

# ArcoraDEX — Full-Sweep Audit

Contracts · SDK · App · CI/Ops — branch `phase3/oracle-hardening`

**Date:** 2026-05-24 (rev 2)

**Chain:** Arc Testnet (5042002)

**Method:** 4× parallel review agents + counter-audit

**Verification:** `git ls-files` / `gh api` / `source read`

## Revision note — rev 2

İlk pass'te üç bulgu hatalıydı ve counter-audit ile tespit edildi; rapordan çıkarıldı (aşağıda **Retracted** bölümü). Yerlerine `gh api` ile yapılan canlı kontrolden gelen **iki gerçek CI hatası** eklendi ( `OPS-A` , `OPS-B` ). False-positive demotion'lar değişmedi.

0

CRITICAL

11

HIGH

15

MEDIUM

2

FALSE  
POSITIVES

3

RETRACTED

## False positives (2)

İki reviewer agent disk'te `.env` dosyaları gördü ve commit edilmiş varsaydı. `git ls-files` ile doğrulandı: **her ikisi de tracked değil, history'de kayıt yok.**

| İDDİA                                                                                                       | DOĞRULAMA                                                                                                                                                                                                                           | SONUÇ                 |
|-------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------------|
| <p><code>FAUCET_PRIVATE_KEY</code><br/>repo'da committed</p> <p><code>app C1</code> <code>ci C-1</code></p> | <p><code>.vercel/</code> root <code>.gitignore</code>'da; <code>git ls-files .vercel/</code> boş; <code>git log -- .vercel/.env.production.local</code> boş.</p> <p>Dosya <code>vercel pull</code> ile üretilen local artifact.</p> | <p>NOT A<br/>LEAK</p> |
| <p><code>DEPLOYER_PRIVATE_KEY</code><br/>repo'da committed</p> <p><code>ci C-2</code></p>                   | <p><code>contracts/.env</code> ve <code>contracts/.env.*</code> root <code>.gitignore</code>'da; <code>git ls-files contracts/.env</code> boş; history'de yok. Testnet-throwaway key zaten user policy gereği.</p>                  | <p>NOT A<br/>LEAK</p> |

## Retracted (3)

Counter-audit aşağıdaki üç bulguyu çürüttü; raporun aktif scope'undan çıkarıldılar.

| ID    | ORIJINAL ID DIA                                                                                                                                            | GERÇEK                                                                                                                                                                                                                                                                                                                                                                 |
|-------|------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| OPS-1 | (critical) GitHub Actions user-level disabled; <code>total_count=0</code> ; workflows hiç çalışmamış                                                       | <code>gh api repos/Kubudak90/arcoradex/actions/permissions</code> → <code>enabled:true, allowed_actions:all</code> . <code>actions/runs?per_page=5</code> → <code>total_count=2</code> , son iki run <code>contracts</code> + <code>slither</code> 2026-05-22'de tetiklenmiş. Tetikleme çalışıyor; sonuçlar <b>failing</b> — yeni bulgular OPS-A ve OPS-B 'ye taşındı. |
| H-9   | (high) <code>guard-record.mjs:35</code> 'teki <code>REGISTRY = 0x9914...</code> memory'deki <code>0x8748...</code> ile uyuşmuyor → yanlış kontrata bakıyor | Dosyada satır 31 + comment: <i>"aggregators are resolved from Registry at startup so the script automatically tracks whatever oracle the Registry currently points at"</i> . <code>0x9914...</code> bu repo için aktif V3 Registry; memory'deki <code>0x8748...</code> farklı deployment epoch'una ait. Hardcode yok, mismatch de yok.                                 |
| M-6   | (medium) <code>usePoolStats</code> <code>queryKey</code> her render'da yeni tuple → gereksiz <code>invalidateQueries</code>                                | <code>usePoolStats.ts:21</code> 'de zaten <code>useMemo</code> ile stable primitive deps: <code>[sdk.chain.id, sdk.addresses.pool]</code> . Reviewer agent kaynağı yanlış okumuş.                                                                                                                                                                                      |

## High (11)

**Live CI status** (`gh api` 2026-05-24): `contracts` ve `slither` workflow'larının 2026-05-22'deki son run'ları **fail**. `app.yml` ve `sdk.yml` hiç tetiklenmemiş — sebep PR #29-#32'lerin path filter'ları, push'lar bu dosyalara dokunmadı (bu beklenen davranış).

| #   | SURFACE   | BULGU                                                                                                                                                                                                                  | FIX                                                                                                                     |
|-----|-----------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-------------------------------------------------------------------------------------------------------------------------|
| H-1 | contracts | ArcoraDexPool._readUsdPrice1e18Mut ( :142-179 ) — lastValidPrice cache'i kendi staleness eşiği OLMADAN fallback olarak kullanılıyor. Oracle kalıcı düşerse pool 30 gün önceki fiyatla sonsuza dek çalışır.             | TokenInfo 'ya maxCacheAgeSeconds ekle; block.timestamp - lastValidPriceAt[token] > max ise NoValidPrice revert.         |
| H-2 | sdk       | EarlyWithdrawError errors.ts:91 'de tanımlı ama src/index.ts:21-34 export bloğunda yok. Consumer'lar instanceof EarlyWithdrawError yapamıyor.                                                                          | Export bloğuna tek satır ekle.                                                                                          |
| H-3 | sdk       | parseContractError switch'inde InvalidOracleTimestamp ve InvalidOracleRound case'leri yok. P3 oracle revert'leri generic ArcoraDexError 'a düşüyor.                                                                    | İki case ekle → OracleStaleError instance döndür.                                                                       |
| H-4 | sdk       | wagmi writeContract simulate'i atlıyor → revert receipt'e status:"reverted" olarak düşüyor, SDK decodeWithdrewEvent "event not found" generic error fırlatıyor. Typed-error yolu sadece privateKeyToAccount path'inde. | Write action'larında status === "reverted" guard'ı + simulateContract ile revert reason recovery → parseContractError . |
| H-5 | app       | app/lib/wagmi.ts:13-22 lokal arcTestnet tanımlıyor; diğer 4 dosya SDK'dan import ediyor. İki farklı obje aynı id ile bundle'da. Bonus: lokal tanımda nativeCurrency.symbol = "USDC" (semantik yanlış görünüyor).       | Lokal defineChain sil, SDK export'unu her yerde kullan.                                                                 |
| H-6 | app       | Faucet TOCTOU — checkRateLimit ( :76 ) ile recordClaim ( :142 ) atomik değil. Aynı serverless instance'da iki eşzamanlı POST → ikisi de geçer, 14 mint tx atılır.                                                      | Per-key in-flight Set : checkRateLimit sonrası key reserve, finally 'de release.                                        |
| H-7 | app       | /api/faucet Origin/Referer enforcement yok. BotID per-page-load signal — cross-origin frame relay'leyebilir.                                                                                                           | Route üstünde origin.startsWith(NEXT_PUBLIC_APP_URL) kontrolü.                                                          |
| H-8 | ops       | arcoradex-feeds.service ve arcoradex-guard-record.service ikisi de /run/arcora/keeper.env                                                                                                                              | Per-tenant path: keeper-feeds.env / keeper-guard.env .                                                                  |

| #     | SURFACE | BULGU                                                                                                                                                                                                                                                                                                                | FIX                                                                                                                                                                                                                                   |
|-------|---------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
|       |         | paylaşıyor; ikisinde de <code>ExecStopPost=rm -f</code> . Timer'lar drift'le faz hizasına gelirse race.                                                                                                                                                                                                              |                                                                                                                                                                                                                                       |
| H-10  | ops     | <code>ops/keepalive/.env.example</code> 7 primary feed listeliyor, <code>P3_SECONDARY_*</code> yok. Fresh provision → secondary feed'ler sessizce stale → OracleAggregator divergence guard görmüyor.                                                                                                                | <code>.env.example</code> 'a 7 secondary ekle.                                                                                                                                                                                        |
| OPS-A | ci      | <code>contracts.yml</code> 2026-05-22'den beri her push'ta fail. Failing step: <code>forge fmt --check</code> (job <code>test</code> , step #5). Main red 2+ gündür — cosmetic ama gate doğru çalışıyor, code style commit'i eksik.                                                                                  | <code>cd contracts &amp;&amp; forge fmt</code> + commit. Tek satır PR.                                                                                                                                                                |
| OPS-B | ci      | <code>slither.yml</code> son run'da Slither analysis fail (medium+ bulgu var) <b>ve</b> SARIF upload da fail oldu — yani <code>M-14</code> 'te teorik dediğim "fail-on:medium + continue-on-error:false → SARIF düşmez" davranışı canlı gerçekleşiyor. GitHub Security tab boş, gerçek bulgular gözle görünür değil. | (i) Slither step'e <code>continue-on-error: true</code> , (ii) merge'i ayrı required status check ile gate'le, (iii) hangi medium'ların fail'e yol açtığını local'de <code>slither contracts/ --sarif results.sarif</code> ile çıkar. |

## Medium (15)

### Contracts (4)

| #   | BULGU                                                                                                                                                                                                 |
|-----|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| M-1 | Eski P3 (P3.5 değil) <code>BatchBuilder</code> <code>SALT = bytes32(0)</code> — <code>scheduleBatch</code> front-run griefing açık. P3.5 düzeltti; eski script'ler retire edilmeli ya da backport.    |
| M-2 | TRYC/BRLC <code>DeployArcoraDexV3.s.sol:90-91</code> 'de <code>maxDeviationBps = 5000</code> (50%) listed, P3 batch 2%'ye çekene kadar 48h attack window. Listing-time 200'e çekersek window kapanır. |
| M-3 | V1 <code>MockChainlinkFeed</code> invariant testlerde <code>roundId = 1</code> sabit — <code>answeredInRound &gt;= roundId</code> branch'i hiç falsify edilmemiş. V2 mock'a geçilmeli.                |
| M-4 | <code>CumulativeDeviationGuard.record()</code> permissionless — window-anchor adversary risk (event-only design mitigates, ama off-chain monitor re-validation bu repo'da spesifik edilmedi).         |

### SDK (3)

| #   | BULGU                                                                                                                                                                                                                                                             |
|-----|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| M-5 | <code>useAllowance</code> <code>sdk.account</code> 'a bağlı — wagmi reconnect cascade'ine fragile. Direkt <code>useAccount().address</code> kullan.                                                                                                               |
| M-7 | <code>useDebounceValue.ts</code> <code>"use client"</code> directive'i eksik — RSC bağlamında import edilirse hard runtime error.                                                                                                                                 |
| M-8 | Test coverage gap: <code>ArcoraDexProvider</code> , <code>useArcoraDex</code> , <code>useDebounceValue</code> için test yok (counter-audit notu: M-3 gibi bu da kısmen kapsamı abartılmış; <code>useDebounceValue</code> testi yok, diğerleri zayıf coverage'lı). |

## App (4)

| #    | BULGU                                                                                                                                                               |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| M-9  | <code>FaucetButton.FailureNotice</code> <code>role="alert"</code> / <code>aria-live</code> yok — screen reader üç failure state'ini announce etmez.                 |
| M-10 | <code>ReservesTable</code> PR #29 refactor'una dahil edilmemiş, hâlâ <code>useEffect + useState</code> pattern'ı. <code>useQuery</code> 'ye taşı.                   |
| M-11 | <code>FaucetButton.TOKEN_LIST</code> server'daki <code>FAUCET_TOKENS</code> 'ın hard-coded duplicate'i — drift risk. Tek kaynaktan import.                          |
| M-12 | <code>vercel.json</code> 'da <code>/api/faucet</code> için <code>maxDuration</code> yok — 7 sequential mint + 8s receipt timeout Hobby plan default 10s'i aşabilir. |

## CI / Ops (4)

| #    | BULGU                                                                                                                                                               |
|------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| M-13 | Tüm action'lar tag-pinned ( <code>@v4</code> , <code>@v3</code> , <code>@nightly</code> ), SHA-pinned değil — supply chain saldırı yüzeyi.                          |
| M-14 | <code>slither.yml</code> <code>continue-on-error:false</code> + <code>fail-on:medium</code> kombinasyonu medium bulunan run'larda SARIF upload'ını bypass edebilir. |
| M-15 | <code>slither.yml</code> path filter'ı <code>.gitmodules</code> 'u tutmuyor → <code>contracts/lib/</code> submodule bump'ları slither'ı tetiklemez.                 |
| M-16 | <code>sdk.yml</code> + <code>app.yml</code> path filter'ları <code>pnpm-workspace.yaml</code> ve <code>tsconfig*.json</code> 'u kapsamıyor.                         |

## Verified clean

**Contracts:** Reentrancy/CEI tüm yazma path'lerinde temiz · pause-guardian role separation ( `unpause` sadece Timelock) · oracle staleness + round validation (4 koşul birden) · P3 batch identity (schedule/execute simetrisi) · virtual-shares EIP-4626 inflation defence · JIT/MEV min-hold + LP transfer hook · 4 invariant test · P3.5 non-zero salt (G-3 fix) · Timelock 48h delay lockdown.

**SDK:** bigint precision (no premature `Number()`) · EIP-55 boundary checks · 6/18 decimals handling · tree-shaking ( `splitting` + `treeshake` + `sideEffects` ) · subscription cleanup ( `watchContractEvent` / `watchBlockNumber` unsubscribe).

**App:** NEXT\_PUBLIC\_\* secret leak yüzeyi temiz · BotID server/client boundary izole · `protect` path/route eşleşmesi doğru · wagmi `ssr: true` · Radix Dialog a11y temeli · `WC_PROJECT_ID` graceful skip.

**CI / Ops:** `pull_request_target` hiçbir workflow'da yok · `set +x` Vault script'inde · `--frozen-lockfile` her install'da · oneshot service'lerde restart loop yok · Vault AppRole secret stdin üzerinden geçiyor.

## Önerilen sıralama

Counter-audit'ın önerdiği sıra: `H-1` → `H-4` → `H-2/H-3` → `H-6` → `H-8/H-10`. Bunun üzerine CI bulgularını ekleyerek:

1. **Quick fix (5 dakika)** → `OPS-A`: `cd contracts && forge fmt && git commit`. Main red 2 gündür, tek satır PR ile temizlenir.
2. **Phase F1 PR (oracle hardening close-out)** → `H-1` (cache TTL) + `H-3` (parseContractError oracle case'leri) + `H-4` (wagmi revert recovery).
3. **Phase F2 PR (SDK + app API hygiene)** → `H-2` (EarlyWithdrawError export) + `H-5` (arcTestnet drift) + `H-6` (faucet TOCTOU) + `H-7` (Origin check, severity dispute notunu PR description'a ekle).
4. **Ops PR** → `H-8` (per-tenant systemd env path) + `H-10` (P3\_SECONDARY\_\* in .env.example).
5. **CI hardening PR** → `OPS-B` (slither continue-on-error) + `M-13/M-15/M-16` (action SHA-pin + path filter genişletme).
6. Geriye kalan medium'lar opportunistic; `M-9` + `M-10` + `M-11` küçük tek-PR bundle olabilir.

### Counter-audit metodolojisi notu

Reviewer agent'lar (4x) `grep` + statik dosya okuma ile çalıştı; `gh api` (live CI) ve `git ls-files` (gerçek tracking) sorgulamadılar. Rev 2'deki üç retract bunun doğrudan sonucu. Önümüzdeki audit pass'lerinde reviewer prompt'larına "claim verifying her CRITICAL/HIGH için en az bir live API veya git query çalıştır" kuralı eklenmeli.

generated 2026-05-24 · rev 2 (counter-audit applied) · branch docs/audits/2026-05-24-full-sweep-audit.html